

Primer reporte tecnico de rendimiento y seguridad en produccion: GyrMonitor

Fecha de elaboracion: 9 de julio de 2026

Tipo de reporte: auditoria tecnica inicial de produccion

Entregable final: PDF exportado en docs/reports/first-report/exports/

1. Resumen ejecutivo

Se realizo una auditoria tecnica inicial sobre las superficies productivas de GyrMonitor usando exclusivamente Lighthouse y ZAP by Checkmarx/OWASP ZAP. El frontend productivo evaluado fue <https://gyr-monitor.vercel.app/> y el backend productivo evaluado fue <https://gyrmonitor-production.up.railway.app/api/v1>.

Lighthouse reporto un estado favorable del frontend: Performance 99, Accessibility 100, Best Practices 100 y SEO 90. Las oportunidades principales son agregar una meta descripcion y revisar JavaScript no utilizado.

ZAP by Checkmarx/OWASP ZAP 2.17.0 se ejecuto mediante el lanzador normal zap.sh. En el reintento del frontend, ZAP completo la fase activa y reporto 0 hallazgos altos, 3 medios, 1 bajo y 5 informativos. El backend productivo completo reporto 0 hallazgos altos, 0 medios, 3 bajos y 1 informativo.

2. Alcance y metodologia

Superficie	URL	Herramienta
Frontend productivo	https://gyr-monitor.vercel.app/	Lighthouse, ZAP
Backend productivo	https://gyrmonitor-production.up.railway.app/api/v1	ZAP

Herramienta	Version / modo	Evidencia
Lighthouse	13.4.0	evidence/lighthouse/lighthouse-production-frontend.report.json, .html
ZAP by Checkmarx / OWASP ZAP	2.17.0, zap.sh -cmd - quickurl	evidence/zap/zap-production-frontend-retry-quick-scan.html, zap-production-backend-quick-scan.html
curl	Captura de encabezados HTTP	production-frontend-headers.txt, production-backend-headers.txt

3. Resultados de Lighthouse

URL evaluada: <https://gyr-monitor.vercel.app/>

Fecha tecnica: 2026-07-09T00:24:24.032Z. Evidencia: lighthouse-production-frontend.report.json.

Categoria	Puntaje	Metrica	Resultado
Performance	99	First Contentful Paint	1.6 s
Accessibility	100	Largest Contentful Paint	1.6 s
Best Practices	100	Total Blocking Time	0 ms
SEO	90	Cumulative Layout Shift / Speed Index	0 / 1.7 s

- El documento no tiene meta descripcion.
- Lighthouse identifico oportunidad de reducir JavaScript no utilizado.

- Lighthouse registro la observacion "Network dependency tree" como diagnostico.

4. Auditoria de seguridad con ZAP by Checkmarx

4.1 Frontend productivo

Objetivo: <https://gyr-monitor.vercel.app/>. **Evidencia:** zap-production-frontend-retry-quick-scan.html.

ZAP normal inicio correctamente con Java 17.0.17 y JVM -Xmx4608m. En el reintento, el escaneo uso spider tradicional y fase activa, completo al 100% y escribio el reporte HTML correspondiente.

La captura de encabezados del frontend productivo registro HTTP/2 200, server: Vercel, strict-transport-security: max-age=63072000; includeSubDomains; preload, cache-control: public, max-age=0, must-revalidate y access-control-allow-origin: *.

Nivel de riesgo	Numero de alertas
Alto	0
Medio	3
Bajo	1
Informativo	5
Falsos positivos marcados	0

ID ZAP	Hallazgo	Riesgo	Instancias	Evidencia
10038	Content Security Policy Header Not Set	Medio	1	Ausencia de CSP
10098	Cross-Domain Misconfiguration	Medio	4	Access-Control-Allow-Origin: *
10020	Missing Anti-clickjacking Header	Medio	1	Ausencia de X-Frame-Options o frame-ancestors
10021	X-Content-Type-Options Header Missing	Bajo	4	Ausencia de X-Content-Type-Options: nosniff
10027, 10109, 10015, 10050, 10104	Hallazgos informativos	Informativo	7 + sistemico	zap-production-frontend-retry-quick-scan.html

4.2 Backend productivo

Objetivo: <https://gyrmonitor-production.up.railway.app/api/v1>. **Evidencia:** zap-production-backend-quick-scan.html.

Nivel de riesgo	Numero de alertas
Alto	0
Medio	0
Bajo	3
Informativo	1
Falsos positivos marcados	0

ID ZAP	Hallazgo	Riesgo	Instancias	Evidencia
10037	Server Leaks Information via X-Powered-By	Bajo	3	x-powered-by: Express

10035	Strict-Transport-Security Header Not Set	Bajo	3	Ausencia de HSTS en backend
10021	X-Content-Type-Options Header Missing	Bajo	1	Ausencia de X-Content-Type-Options: nosniff
10015	Re-examine Cache-control Directives	Informativo	1	Revision de cache

5. Correcciones por aplicar

Prioridad	Evidencia	Correccion propuesta	Justificacion tecnica	Impacto esperado	Area	Estado
Alta	ZAP 10035	Configurar Strict-Transport-Security en el backend.	HSTS reduce downgrade y uso accidental de HTTP.	Cierre de 3 instancias bajas.	Backend / Railway	Pendiente
Alta	ZAP 10037	Deshabilitar X-Powered-By.	Reduce fingerprinting tecnologico.	Cierre de 3 instancias bajas.	Backend	Pendiente
Alta	ZAP frontend 10038 y 10020	Configurar CSP con frame-ancestors.	Reduce XSS y clickjacking.	Cierre de 2 hallazgos medios.	Frontend / Vercel	Pendiente
Alta	ZAP frontend 10098	Restringir o justificar CORS del frontend.	ZAP evidencio Access-Control-Allow-Origin: *.	Reduccion del hallazgo medio de CORS.	Frontend / Vercel	Pendiente
Media	ZAP 10021	Agregar X-Content-Type-Options: nosniff.	Evita interpretacion MIME incorrecta.	Cierre del hallazgo bajo.	Backend / Railway	Pendiente
Media	ZAP frontend 10021	Agregar X-Content-Type-Options: nosniff en frontend.	El frontend reporto 4 instancias.	Cierre del hallazgo bajo frontend.	Frontend / Vercel	Pendiente
Media	Lighthouse SEO	Agregar meta descripcion al frontend.	Lighthouse reporto ausencia de meta descripcion.	Mejora esperada de SEO.	Frontend	Pendiente
Media	Lighthouse diagnostics	Revisar JavaScript no utilizado y evaluar carga diferida.	Reduce bytes iniciales.	Mayor margen de rendimiento.	Frontend	Pendiente
Baja	ZAP 10015	Definir politica de cache para respuestas JSON.	Reduce ambigüedad operativa.	Mejor control de cache.	Backend / Railway	Pendiente
Baja	ZAP frontend 10015 y 10050	Revisar directivas de cache del frontend.	La politica debe distinguir HTML y assets con hash.	Mejor control de actualizaciones.	Frontend / Vercel	Pendiente

6. Conclusiones

El frontend productivo presenta resultados fuertes en Lighthouse, con rendimiento casi maximo y accesibilidad completa. Las mejoras mas relevantes son de calidad SEO y optimizacion preventiva de JavaScript.

El backend productivo no presento hallazgos altos ni medios en ZAP. Los hallazgos bajos se concentran en encabezados HTTP de endurecimiento: ocultar X-Powered-By, agregar HSTS y agregar X-Content-Type-Options.

El reintento del escaneo ZAP del frontend productivo se completo correctamente y expuso hallazgos medios de encabezados y CORS. Estos hallazgos deben priorizarse junto con el endurecimiento del backend.

7. Anexo de evidencias

- docs/reports/first-report/evidence/lighthouse/lighthouse-production-frontend.report.json
- docs/reports/first-report/evidence/lighthouse/lighthouse-production-frontend.report.html
- docs/reports/first-report/evidence/zap/zap-production-frontend-retry-quick-scan.html
- docs/reports/first-report/evidence/zap/zap-production-backend-quick-scan.html
- docs/reports/first-report/evidence/zap/production-frontend-headers.txt
- docs/reports/first-report/evidence/zap/production-backend-headers.txt